

Software Testing Document (STD) Report

Test Date: March 24, 2026
Tested By: Johnatan Milrad
Test Source: <https://www.roladin.co.il/>

Pass: 11 | Partial: 18 | Fail: 2

Overall Status: FAIL

Critical Issues: 2

High Priority: 6

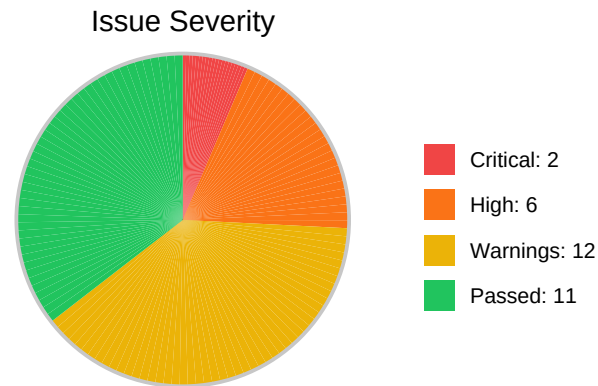
Warnings: 12

Passed Checks: 11

Success Rate: 35.5%

Total Tests: 31

SUMMARY ISSUES & FINDINGS



CRITICAL ISSUES (2)

1. Missing CSP

Location: <https://www.roladin.co.il/>

No Content-Security-Policy header is present. Attackers can inject arbitrary scripts.

Impact: Full cross-site scripting (XSS) attack surface — malicious scripts can steal cookies, session tokens, and exfiltrate data.

Fix: Add a strict CSP: ``Content-Security-Policy: default-src 'self'; script-src 'self'; object-src 'none';``

2. Missing HSTS

Location: <https://www.roladin.co.il/>

No Strict-Transport-Security header. Browsers can be downgraded to HTTP via MITM.

Impact: Man-in-the-middle attackers can strip HTTPS and intercept all traffic in plaintext.

Fix: Add: ``Strict-Transport-Security: max-age=31536000; includeSubDomains; preload``

HIGH PRIORITY ISSUES (6)

1. Clickjacking Vulnerability

Location: <https://www.roladin.co.il/>

No X-Frame-Options or CSP frame-ancestors directive. Page can be embedded in iframes for clickjacking.

Fix: Add ``X-Frame-Options: DENY`` or CSP ``frame-ancestors 'none'``.

2. Sensitive Data in HTML Comments

Location: <https://www.roladin.co.il/>

1 HTML comment(s) contain potentially sensitive keywords (password, key, token, secret, debug, etc.).

Fix: Remove all HTML comments from production builds. Use build-time comment stripping.

3. Potential CSRF Vulnerability

Location: <https://www.roladin.co.il/>

1 form(s) found without visible CSRF token fields.

Fix: Add a CSRF token hidden input to every state-changing form. Verify server-side validation.

4. Buttons Without Accessible Labels

Location: <https://www.roladin.co.il/>

1 button(s) found with no visible text and no aria-label. Screen readers and users cannot identify what these buttons do.

Fix: Add descriptive text, aria-label, or title attribute to every button. Example: `<button aria-label='Close dialog'> </button>`

5. Dead / Non-Functional Links

Location: <https://www.roladin.co.il/>

30 link(s) found with href="#", href="javascript:...", or empty href. These do nothing when clicked — a real functionality failure.

Fix: Replace dead links with real URLs or use <button> elements for non-navigation interactions. Never use href='javascript:void(0)'.

6. Images Missing Alt Text

Location: <https://www.roladin.co.il/>

20 image(s) found with missing or empty alt attribute. Screen readers cannot describe these images.

Fix: Add descriptive alt text to all meaningful images. For decorative images, use alt="".

WARNINGS (12)

1. Missing Referrer-Policy

Location: <https://www.roladin.co.il/>

No Referrer-Policy header. Full URLs (including tokens) may leak to third-party sites via the Referer header.

Fix: Add `Referrer-Policy: strict-origin-when-cross-origin``.

2. Excessive Inline Scripts

Location: <https://www.roladin.co.il/>

20 inline `<script>` blocks detected. Inline scripts bypass CSP nonce protection and are harder to audit.

Fix: Move inline scripts to external .js files. Use CSP nonces for any that must remain inline.

3. Mixed Content Warning

Location: <https://www.roladin.co.il/>

HTTP resources referenced on an HTTPS page. Browsers block or warn about mixed content.

Fix: Update all resource URLs to use HTTPS. Use protocol-relative URLs (`//`) where possible.

4. Unsandboxed iframes

Location: <https://www.roladin.co.il/>

1 iframe(s) found without a sandbox attribute. They can navigate the top-level page and execute scripts.

Fix: Add `sandbox='allow-scripts allow-same-origin`` (or appropriate restrictions) to all iframes.

5. Data URIs Detected [Bizarre]

Location: <https://www.roladin.co.il/>

4 base64 data URI(s) found. Data URIs can be used to embed executable content.

Fix: Avoid data URIs for anything other than inlined images. Block data: URLs in CSP.

6. Page Response Time Above Target

Location: <https://www.roladin.co.il/>

Response time is 882ms. Acceptable but above the 500ms best-practice target.

Fix: Profile server-side code and consider adding caching headers (Cache-Control, ETag).

7. External Links Missing rel='noopener'

Location: <https://www.roladin.co.il/>

6 external link(s) open in a new tab (target='_blank') without rel='noopener noreferrer'.

Fix: Add rel='noopener noreferrer' to all target='_blank' links.

8. Links Without Accessible Text

Location: <https://www.roladin.co.il/>

24 link(s) have no visible text and no aria-label. Screen readers will read the URL, confusing users.

Fix: Add descriptive text or aria-label to every link. Avoid icon-only links without accessible alternatives.

9. No H1 Heading

Location: <https://www.roladin.co.il/>

Page has no <h1> heading. Every page should have exactly one H1 describing its main topic.

Fix: Add a single <h1> that describes the primary purpose of this page.

10. Missing Permissions-Policy

Location: <https://www.roladin.co.il/>

No Permissions-Policy header. Third-party iframes can access camera, microphone, and geolocation APIs.

Fix: Add `Permissions-Policy: camera=(), microphone=(), geolocation=()` to restrict API access.

11. No Skip Navigation Link

Location: <https://www.roladin.co.il/>

No 'Skip to main content' link found. Keyboard users must tab through the entire navigation on every page.

Fix: Add a skip navigation link as the first focusable element: `<a href='#main-content' class='sr-only focus:not-sr-only'>Skip to main content</a>`

12. Phone Numbers Not Linked (tel:)

Location: <https://www.roladin.co.il/>

19 phone number(s) detected that aren't wrapped in tel: links. Mobile users cannot tap to call.

Fix: Wrap phone numbers: `<a href='tel:1774374271'>1774374271</a>`

PASSED CHECKS (11)

1. MIME Sniffing Protection X-Content-Type-Options: nosniff is set.	Location: https://www.roladin.co.il/
2. Mobile Viewport Configured viewport meta tag found — responsive design is supported.	Location: https://www.roladin.co.il/
3. HTTPS Enforced Page is served over HTTPS with TLS encryption.	Location: https://www.roladin.co.il/
4. Title Tag Present Page has a <title> tag — good for SEO and browser tab display.	Location: https://www.roladin.co.il/
5. Favicon Configured Favicon link tag is present.	Location: https://www.roladin.co.il/
6. Forms Present and Detectable 1 form(s) detected on the page.	Location: https://www.roladin.co.il/
7. <nav> Landmark Present Semantic <nav> element found — navigation is structured for accessibility.	Location: https://www.roladin.co.il/
8. HTML lang Attribute Set The <html> element has a lang attribute — screen readers know the page language.	Location: https://www.roladin.co.il/
9. ARIA Attributes Used ARIA attributes detected — accessibility roles and states are being communicated to assistive technologies.	Location: https://www.roladin.co.il/
10. Print Stylesheet Present A print media query or print stylesheet is defined — the page has been optimised for printing.	Location: https://www.roladin.co.il/
11. Open Graph Tags Present Open Graph meta tags found — social media sharing will show a rich preview.	Location: https://www.roladin.co.il/

TEST PLAN OVERVIEW

This section describes the test strategy and objectives before execution.

Test Scope by Category:

1. MISSING (4 tests)

1.1 Test Objective: Missing CSP

Goal: No Content-Security-Policy header is present. Attackers can inject arbitrary scripts.

1.2 Test Objective: Missing HSTS

Goal: No Strict-Transport-Security header. Browsers can be downgraded to HTTP via MITM.

1.3 Test Objective: Missing Referrer-Policy

Goal: No Referrer-Policy header. Full URLs (including tokens) may leak to third-party sites via the Referer header.

1.4 Test Objective: Missing Permissions-Policy

Goal: No Permissions-Policy header. Third-party iframes can access camera, microphone, and geolocation APIs.

2. CLICKJACKING (1 tests)

2.1 Test Objective: Clickjacking Vulnerability

Goal: No X-Frame-Options or CSP frame-ancestors directive. Page can be embedded in iframes for clickjacking.

3. MIME (1 tests)

3.1 Test Objective: MIME Sniffing Protection

Goal: X-Content-Type-Options: nosniff is set.

4. MOBILE (1 tests)

4.1 Test Objective: Mobile Viewport Configured

Goal: viewport meta tag found — responsive design is supported.

5. EXCESSIVE (1 tests)

5.1 Test Objective: Excessive Inline Scripts

Goal: 20 inline <script> blocks detected. Inline scripts bypass CSP nonce protection and are harder to audit.

6. SENSITIVE (1 tests)

6.1 Test Objective: Sensitive Data in HTML Comments

Goal: 1 HTML comment(s) contain potentially sensitive keywords (password, key, token, secret, debug, etc.).

7. POTENTIAL (1 tests)

7.1 Test Objective: Potential CSRF Vulnerability

Goal: 1 form(s) found without visible CSRF token fields.

8. MIXED (1 tests)

8.1 Test Objective: Mixed Content Warning

Goal: HTTP resources referenced on an HTTPS page. Browsers block or warn about mixed content.

9. UNSANDBOXED (1 tests)

9.1 Test Objective: Unsandboxed iframes

Goal: 1 iframe(s) found without a sandbox attribute. They can navigate the top-level page and execute scripts.

10. DATA (1 tests)

10.1 Test Objective: Data URIs Detected [Bizarre]

Goal: 4 base64 data URI(s) found. Data URIs can be used to embed executable content.

11. HTTPS (1 tests)

11.1 Test Objective: HTTPS Enforced

Goal: Page is served over HTTPS with TLS encryption.

12. TITLE (1 tests)

12.1 Test Objective: Title Tag Present

Goal: Page has a <title> tag — good for SEO and browser tab display.

13. FAVICON (1 tests)

13.1 Test Objective: Favicon Configured

Goal: Favicon link tag is present.

14. PAGE (1 tests)

14.1 Test Objective: Page Response Time Above Target

Goal: Response time is 882ms. Acceptable but above the 500ms best-practice target.

15. BUTTONS (1 tests)

15.1 Test Objective: Buttons Without Accessible Labels

Goal: 1 button(s) found with no visible text and no aria-label. Screen readers and users cannot identify what these buttons do.

16. DEAD (1 tests)

16.1 Test Objective: Dead / Non-Functional Links

Goal: 30 link(s) found with href="#", href="javascript:...", or empty href. These do nothing when clicked — a real functionality failure.

17. EXTERNAL (1 tests)

17.1 Test Objective: External Links Missing rel='noopener'

Goal: 6 external link(s) open in a new tab (target='_blank') without rel='noopener noreferrer'.

18. LINKS (1 tests)

18.1 Test Objective: Links Without Accessible Text

Goal: 24 link(s) have no visible text and no aria-label. Screen readers will read the URL, confusing users.

19. FORMS (1 tests)

19.1 Test Objective: Forms Present and Detectable

Goal: 1 form(s) detected on the page.

20. IMAGES (1 tests)

20.1 Test Objective: Images Missing Alt Text

Goal: 20 image(s) found with missing or empty alt attribute. Screen readers cannot describe these images.

21. <NAV> (1 tests)

21.1 Test Objective: <nav> Landmark Present

Goal: Semantic <nav> element found — navigation is structured for accessibility.

22. NO (2 tests)

22.1 Test Objective: No Skip Navigation Link

Goal: No 'Skip to main content' link found. Keyboard users must tab through the entire navigation on every page.

22.2 Test Objective: No H1 Heading

Goal: Page has no <h1> heading. Every page should have exactly one H1 describing its main topic.

23. HTML (1 tests)

23.1 Test Objective: HTML lang Attribute Set

Goal: The <html> element has a lang attribute — screen readers know the page language.

24. ARIA (1 tests)

24.1 Test Objective: ARIA Attributes Used

Goal: ARIA attributes detected — accessibility roles and states are being communicated to assistive technologies.

25. PHONE (1 tests)

25.1 Test Objective: Phone Numbers Not Linked (tel:)

Goal: 19 phone number(s) detected that aren't wrapped in tel: links. Mobile users cannot tap to call.

26. PRINT (1 tests)

26.1 Test Objective: Print Stylesheet Present

Goal: A print media query or print stylesheet is defined — the page has been optimised for printing.

27. OPEN (1 tests)

27.1 Test Objective: Open Graph Tags Present

Goal: Open Graph meta tags found — social media sharing will show a rich preview.

TEST EXECUTION RESULTS

This section shows what was expected vs what actually happened during testing.

MISSING

Test Name	Status	Description	Actions Performed	Expected vs Actual
Missing CSP	FAIL	No Content-Security-Policy header is present. Attackers can inject arbitrary scripts.	N/A	N/A
Missing HSTS	FAIL	No Strict-Transport-Security header. Browsers can be downgraded to HTTP via MITM.	N/A	N/A
Missing Referrer-Policy	PARTIAL	No Referrer-Policy header. Full URLs (including tokens) may leak to third-party sites via the Referer header.	N/A	N/A
Missing Permissions-Policy	PARTIAL	No Permissions-Policy header. Third-party iframes can access camera, microphone, and geolocation APIs.	N/A	N/A

CLICKJACKING

Test Name	Status	Description	Actions Performed	Expected vs Actual
Clickjacking Vulnerability	PARTIAL	No X-Frame-Options or CSP frame-ancestors directive. Page can be embedded in iframes for clickjacking.	N/A	N/A

MIME

Test Name	Status	Description	Actions Performed	Expected vs Actual
MIME Sniffing Protection	PASS	X-Content-Type-Options: nosniff is set.	N/A	N/A

MOBILE

Test Name	Status	Description	Actions Performed	Expected vs Actual
Mobile Viewport Configured	PASS	viewport meta tag found — responsive design is supported.	N/A	N/A

EXCESSIVE

Test Name	Status	Description	Actions Performed	Expected vs Actual
Excessive Inline Scripts	PARTIAL	20 inline <script> blocks detected. Inline scripts bypass CSP nonce protection and are harder to audit.	N/A	N/A

SENSITIVE

Test Name	Status	Description	Actions Performed	Expected vs Actual
Sensitive Data in HTML Comments	PARTIAL	1 HTML comment(s) contain potentially sensitive keywords (password, key, token, secret, debug, etc.).	N/A	N/A

POTENTIAL

Test Name	Status	Description	Actions Performed	Expected vs Actual
Potential CSRF Vulnerability	PARTIAL	1 form(s) found without visible CSRF token fields.	N/A	N/A

MIXED

Test Name	Status	Description	Actions Performed	Expected vs Actual
Mixed Content Warning	PARTIAL	HTTP resources referenced on an HTTPS page. Browsers block or warn about mixed content.	N/A	N/A

UNSANDBOXED

Test Name	Status	Description	Actions Performed	Expected vs Actual
Unsandboxed iframes	PARTIAL	1 iframe(s) found without a sandbox attribute. They can navigate the top-level page and execute scripts.	N/A	N/A

DATA

Test Name	Status	Description	Actions Performed	Expected vs Actual
Data URIs Detected [Bizarre]	PARTIAL	4 base64 data URI(s) found. Data URIs can be used to embed executable content.	N/A	N/A

HTTPS

Test Name	Status	Description	Actions Performed	Expected vs Actual
HTTPS Enforced	PASS	Page is served over HTTPS with TLS encryption.	N/A	N/A

TITLE

Test Name	Status	Description	Actions Performed	Expected vs Actual
Title Tag Present	PASS	Page has a <title> tag — good for SEO and browser tab display.	N/A	N/A

FAVICON

Test Name	Status	Description	Actions Performed	Expected vs Actual
Favicon Configured	PASS	Favicon link tag is present.	N/A	N/A

PAGE

Test Name	Status	Description	Actions Performed	Expected vs Actual
Page Response Time Above Target	PARTIAL	Response time is 882ms. Acceptable but above the 500ms best-practice target.	N/A	N/A

BUTTONS

Test Name	Status	Description	Actions Performed	Expected vs Actual
Buttons Without Accessible Labels	PARTIAL	1 button(s) found with no visible text and no aria-label. Screen readers and users cannot identify what these buttons do.	N/A	N/A

DEAD

Test Name	Status	Description	Actions Performed	Expected vs Actual
-----------	--------	-------------	-------------------	--------------------

Test Name	Status	Description	Actions Performed	Expected vs Actual
Dead / Non-Functional Links	PARTIAL	30 link(s) found with href="#", href="javascript:...", or empty href. These do nothing when clicked — a real functionality failure.	N/A	N/A

EXTERNAL

Test Name	Status	Description	Actions Performed	Expected vs Actual
External Links Missing rel='noopener'	PARTIAL	6 external link(s) open in a new tab (target='_blank') without rel='noopener noreferrer'.	N/A	N/A

LINKS

Test Name	Status	Description	Actions Performed	Expected vs Actual
Links Without Accessible Text	PARTIAL	24 link(s) have no visible text and no aria-label. Screen readers will read the URL, confusing users.	N/A	N/A

FORMS

Test Name	Status	Description	Actions Performed	Expected vs Actual
Forms Present and Detectable	PASS	1 form(s) detected on the page.	N/A	N/A

IMAGES

Test Name	Status	Description	Actions Performed	Expected vs Actual
-----------	--------	-------------	-------------------	--------------------

Test Name	Status	Description	Actions Performed	Expected vs Actual
Images Missing Alt Text	PARTIAL	20 image(s) found with missing or empty alt attribute. Screen readers cannot describe these images.	N/A	N/A

<NAV>

Test Name	Status	Description	Actions Performed	Expected vs Actual
<nav> Landmark Present	PASS	Semantic <nav> element found — navigation is structured for accessibility.	N/A	N/A

NO

Test Name	Status	Description	Actions Performed	Expected vs Actual
No Skip Navigation Link	PARTIAL	No 'Skip to main content' link found. Keyboard users must tab through the entire navigation on every page.	N/A	N/A
No H1 Heading	PARTIAL	Page has no <h1> heading. Every page should have exactly one H1 describing its main topic.	N/A	N/A

HTML

Test Name	Status	Description	Actions Performed	Expected vs Actual
HTML lang Attribute Set	PASS	The <html> element has a lang attribute — screen readers know the page language.	N/A	N/A

ARIA

Test Name	Status	Description	Actions Performed	Expected vs Actual
ARIA Attributes Used	PASS	ARIA attributes detected — accessibility roles and states are being communicated to assistive technologies.	N/A	N/A

PHONE

Test Name	Status	Description	Actions Performed	Expected vs Actual
Phone Numbers Not Linked (tel:)	PARTIAL	19 phone number(s) detected that aren't wrapped in tel: links. Mobile users cannot tap to call.	N/A	N/A

PRINT

Test Name	Status	Description	Actions Performed	Expected vs Actual
Print Stylesheet Present	PASS	A print media query or print stylesheet is defined — the page has been optimised for printing.	N/A	N/A

OPEN

Test Name	Status	Description	Actions Performed	Expected vs Actual
Open Graph Tags Present	PASS	Open Graph meta tags found — social media sharing will show a rich preview.	N/A	N/A